Marco Legal, Normativa Sanitaria y Arquitectura de Ciberseguridad

Sistema de Gestión de Citas y Expedientes Clínicos de Fisioterapia (fisio-citas)

Documento Técnico de Auditoría Legal y Ciberseguridad | Versión 1.0 | Normativa: LFPDPPP & NOM-004-SSA3-2012

1. Resumen Ejecutivo

El proyecto **fisio-citas** es una aplicación web diseñada para la administración integral de pacientes, agendamiento de citas y expedientes clínicos en un consultorio de fisioterapia en México. La solución responde a la necesidad de gestionar una agenda dinámica de dos espacios simultáneos (bloques de 60 minutos) y registrar de forma estructurada la información clínica del paciente.

A diferencia de sistemas genéricos de citas, la atención fisioterapéutica involucra la recabación de **datos personales sensibles de salud** (alergias, antecedentes patológicos, diagnósticos, historial de lesiones y notas de evolución). Por esta razón, la arquitectura del sistema prescinde de integraciones externas complejas e inseguras (como Google Calendar con tokens de larga duración) en favor de una infraestructura propia centralizada en Supabase sobre PostgreSQL, garantizando cifrado HTTPS, aislamiento estricto por Row Level Security (RLS) y mecanismos de respaldo local para cumplir con la conservación obligatoria de registros por 5 años.

2. Marco Legal Mexicano y Responsabilidades Diferenciadas

El marco regulatorio mexicano impone obligaciones estrictas tanto para el prestador de servicios de salud como para el desarrollador tecnológico. La legislación aplicable se divide en dos ordenamientos fundamentales:

2.1. Ley Federal de Protección de Datos Personales en Posesión de los Particulares (LFPDPPP)

- **Clasificación de Datos Sensibles (Art. 3, Fracc. VI):** Los datos de salud (alergias, padecimientos, notas de tratamiento y antecedentes) se clasifican legalmente como datos personales sensibles. Su tratamiento indebido o filtración puede originar discriminación o un riesgo grave para el titular.
- **Consentimiento Expreso y por Escrito (Arts. 8 y 9):** El tratamiento de datos personales sensibles requiere la autorización explícita del paciente. En entornos digitales, esto se implementa mediante casillas de verificación obligatorias (privacy_consent) previas al registro, vinculadas al Aviso de Privacidad.
- **Aviso de Privacidad y Derechos ARCO (Arts. 15, 16, 17 y 21):** El responsable debe poner a disposición del paciente el Aviso de Privacidad e instrumentar procedimientos para atender solicitudes de Acceso, Rectificación, Cancelación y Oposición (ARCO).

Rol Legal	Entidad	Obligaciones Principales
Responsable del Tratamiento	Fisioterapeuta	Poner a disposición el Aviso de Privacidad, recabar el consentimiento expreso, gestionar derechos ARCO y definir las finalidades de la atención clínica.
Encargado del Tratamiento	Desarrollador / Proveedor de Software	Tratar datos únicamente bajo instrucciones del Responsable, firmar acuerdo DPA, implementar medidas técnicas (RLS, cifrado), garantizar confidencialidad y no comercializar la información.

2.2. NOM-004-SSA3-2012 (Del Expediente Clínico)

La Norma Oficial Mexicana NOM-004-SSA3-2012 regula la integración y manejo del expediente clínico en todo el sector salud privado en México:

- **Conservación Mínima de 5 Años (Numeral 5.4):** Los registros clínicos deben conservarse obligatoriamente por un periodo mínimo de 5 años contados a partir de la fecha del último acto médico. El sistema debe garantizar la disponibilidad y prevenir borrados accidentales.
- **Confidencialidad y Titularidad (Numeral 5.4 y 5.5):** El consultorio es propietario del expediente, pero el paciente mantiene la titularidad sobre la información y tiene derecho a recibir copias o resúmenes clínicos en cualquier momento.
- **Notas de Evolución por Sesión (Numerales 6.1 y 6.2):** Cada atención física debe respaldarse con una nota clínica detallada que incluya fecha, hora, estado del paciente, tratamiento aplicado e identificación del profesional.

3. Matriz de Análisis de Amenazas y Vulnerabilidades

A continuación se detallan los riesgos de seguridad identificados para el consultorio, evaluados conforme a su impacto operativo y normativo:

Amenaza	Impacto	Probabilidad	Medida Preventiva	Prueba de Verificación
Acceso no autorizado a expedientes de otros pacientes (IDOR / Broken Access)	**Alto**	Media	Habilitar Row Level Security (RLS) en Supabase/PostgreSQL restringido estrictamente a auth.uid() = user_id.	Consultar la API con un token JWT anónimo o de otro usuario; debe retornar 0 filas.

Amenaza	Impacto	Probabilidad	Medida Preventiva	Prueba de Verificación
Sobrecupo de citas (>2 pacientes simultáneos por hora)	Medio	Alta	Aplicar restricción de exclusión mediante índice GIST sobre el horario (tstzrange) en slot_number IN (1, 2).	Enviar 2 peticiones POST simultáneas al mismo horario y espacio; la segunda debe ser rechazada.
Fuga de datos médicos hacia servicios de terceros (Google Calendar)	**Alto**	Media	Desacoplar la aplicación de Google Calendar, procesando las citas 100% dentro de la BD propia.	Inspeccionar peticiones de red y verificar la ausencia de llamadas a APIs externas con datos clínicos.
Pérdida de datos por fallo del servidor o inactivación de cuenta	**Alto**	Media	Módulo de exportación local en un clic (JSON/CSV) y respaldos lógicos con Supabase CLI.	Ejecutar la exportación, borrar una fila de prueba e importar el archivo para restaurarla.

4. Requisitos de Seguridad Verificables (REQ-SEC)

REQ-SEC-01: Validación Estricta en el Servidor: El backend debe revalidar la estructura, tipos de datos y campos obligatorios antes de procesar inserciones.

> **Criterio de Aceptación:** Una petición POST enviada con datos inválidos (ej. edad = 150) debe ser rechazada con código HTTP 400.

REQ-SEC-02: Aislamiento Multitenant mediante RLS: Las tablas patients y appointments deben tener activado RLS con la política USING (auth.uid() = user_id).

> **Criterio de Aceptación:** Cualquier consulta SELECT o UPDATE realizada por un usuario no autenticado o distinto retorna 0 registros.

REQ-SEC-03: Registro del Consentimiento de Privacidad: La tabla patients debe incorporar la columna privacy_consent boolean NOT NULL DEFAULT false.

> **Criterio de Aceptación:** La interfaz gráfica impide guardar la ficha si la casilla de aceptación del Aviso de Privacidad está desmarcada.

REQ-SEC-04: Restricción de Concurrencia de Espacios: La BD debe validar que slot_number solo acepte valores 1 o 2 y bloquear solapamientos en el mismo rango de 60 minutos.

> **Criterio de Aceptación:** Intentar insertar un tercer registro en el mismo rango de tiempo arroja una excepción SQL.

REQ-SEC-05: Protección de Claves Privilegiadas: La clave service_role de Supabase jamás debe exponerse en el código cliente del navegador ni en repositorios.

> **Criterio de Aceptación:** El código frontend solo contiene la clave anon_key y respeta las políticas RLS habilitadas.

5. Plan de Pruebas y Verificación de Seguridad

ID Prueba	Pasos de Ejecución	Resultado Esperado	Evidencia a Conservar
TEST-01 (RLS)	1. Iniciar sesión con Cuenta A. 2. Crear Paciente X. 3. Iniciar sesión con Cuenta B. 4. Consultar Paciente X por ID.	La API retorna conjunto vacío o error 403 Forbidden.	Captura de pantalla de la respuesta HTTP y registro en logs de Supabase.
TEST-02 (Concurrencia)	1. Agendar Cita 1 (09:00 h, Espacio 1). 2. Agendar Cita 2 (09:00 h, Espacio 2). 3. Intentar agendar Cita 3 (09:00 h, Espacio 1).	Citas 1 y 2 guardadas; Cita 3 rechazada por restricción de BD.	Log de la consola del navegador con el error de restricción SQL.
TEST-03 (Consentimiento)	1. Abrir formulario de alta. 2. Llenar datos omitiendo checkbox de privacidad. 3. Presionar Guardar.	Formulario detiene envío, marca casilla en rojo y no llama a la BD.	Captura de pantalla mostrando el estado de validación visual.
TEST-04 (Restauración)	1. Generar exportación local JSON/CSV. 2. Borrar paciente de prueba. 3. Ejecutar función de importación.	El paciente y sus citas reaparecen intactos.	Archivo JSON/CSV generado y reporte de filas restauradas.

6. Estrategia de Respaldos y Restauración (NOM-004)

Para garantizar la retención obligatoria de 5 años exigida por la NOM-004-SSA3-2012 sin incurring en costos adicionales de infraestructura, el sistema adopta una estrategia dual:

- **Módulo de Exportación Local Autónoma:** La interfaz incluye un botón de exportación en un solo clic que descarga la totalidad de los registros de pacientes y sus notas clínicas en archivos estandarizados JSON o CSV.
- **Procedimiento de Restauración Verificable:** 1. Descargar el archivo backup_fisio_YYYYMMDD.json. 2. En caso de pérdida, ejecutar el script de inicialización schema.sql en Supabase. 3. Importar el archivo a través del módulo de restauración respetando las llaves foráneas (patients -> appointments). 4. Validar que la cantidad de filas restauradas coincida exactamente con el archivo.

7. Requisitos de la Futura Ficha Clínica Completa

Al incorporar el expediente clínico completo en la versión final, se activan los siguientes módulos específicos:

- **Campos Clínicos Estructurados:** Tabla patients con edad (age), alergias (allergies), estudios previos (previous_studies), antecedentes (family_history) y motivo de consulta (consultation_reason).

- **Notas de Evolución por Sesión:** Campo treatment_notes ('Descripción de lo que se le hizo') vinculado cronológicamente a cada cita realizada.
- **Alertas Visuales de Alergias:** Despliegue de distintivos gráficos destacados en color ámbar o rojo en las tarjetas de citas y ficha del paciente para prevenir riesgos físicos durante la consulta.

8. Plan de Tareas Priorizadas para el Desarrollador

- Paso 1: Ejecutar script schema.sql en el Editor SQL de Supabase para crear tablas patients y appointments con restricciones.
- Paso 2: Habilitar Row Level Security (RLS) en ambas tablas aplicando la política auth.uid() = user_id.
- Paso 3: Implementar la autenticación de Supabase (correo y contraseña) en la vista de inicio de sesión.
- Paso 4: Construir el formulario de alta de pacientes integrando la casilla obligatoria privacy_consent.
- Paso 5: Desarrollar la cuadrícula de agenda diaria (bloques de 60 min, Espacios 1 y 2 simultáneos).
- Paso 6: Agregar badges de alerta de alergias en las citas e historial cronológico de sesiones.
- Paso 7: Crear el módulo de exportación de respaldos locales en JSON/CSV.

9. Preguntas Clave para el Fisioterapeuta

- *¿Cuenta actualmente con un texto formal de Aviso de Privacidad para su consultorio o requiere una plantilla base para personalizarla?*
- *Para el campo de 'Estudios previos', ¿es suficiente con anotar textos descriptivos o necesitará en el futuro adjuntar archivos (PDFs/imágenes)?*
- *¿Cuál es el protocolo cuando un paciente cancela una cita: prefiere liberar el espacio inmediatamente o conservar el registro etiquetado como 'Cancelada'?*
- *¿Con qué frecuencia planea realizar sus respaldos locales en la computadora (diaria, semanal o mensual)?*